Project Report: Vulnerability Assessment and Penetration Testing

Name: Mohammad Aamir Siddique

Target IP: 10.0.2.4

---

1. Executive Summary

The objective of this project was to identify and exploit OS Command Injection vulnerabilities within a Linux-based logistics web application. By injecting unauthorized system-level commands through the application's network testing interface, I successfully demonstrated how an attacker could gain unauthorized access to sensitive system information and control server behavior.

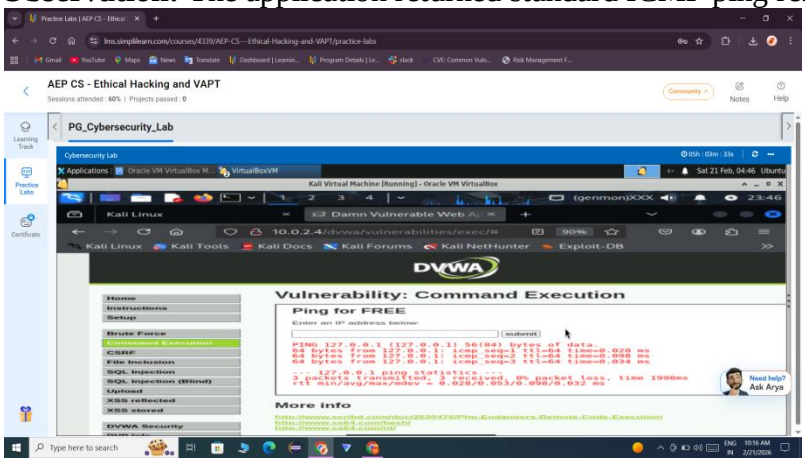
2. Technical Environment

- **Attacker Machine:** Kali Linux (IP: 10.0.2.5)
- **Target Machine:** Metasploitable 2 / Logistics Web App (IP: 10.0.2.4)
- **Vulnerable Application:** DVWA (Command Execution Module)

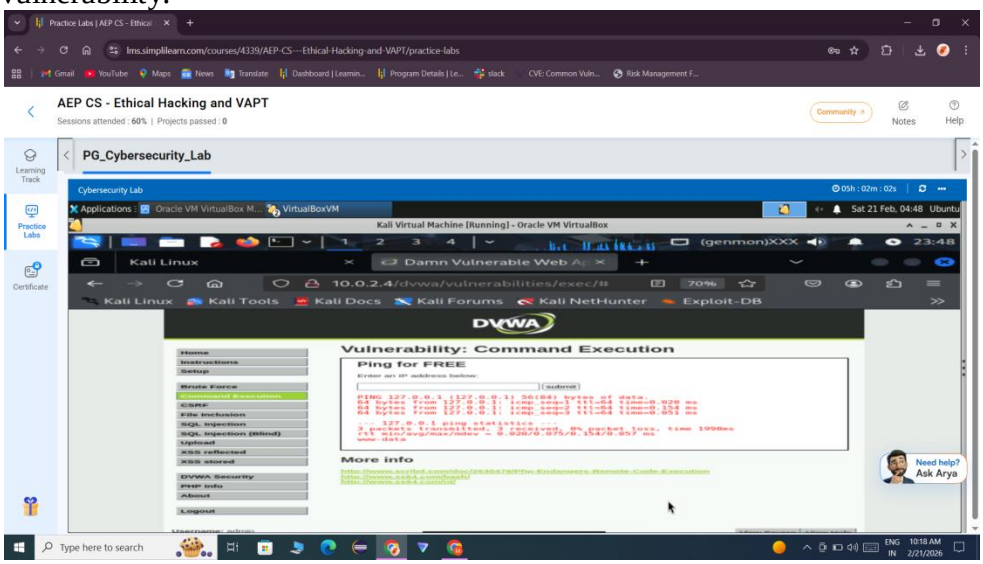
---

3. Phases of Exploitation

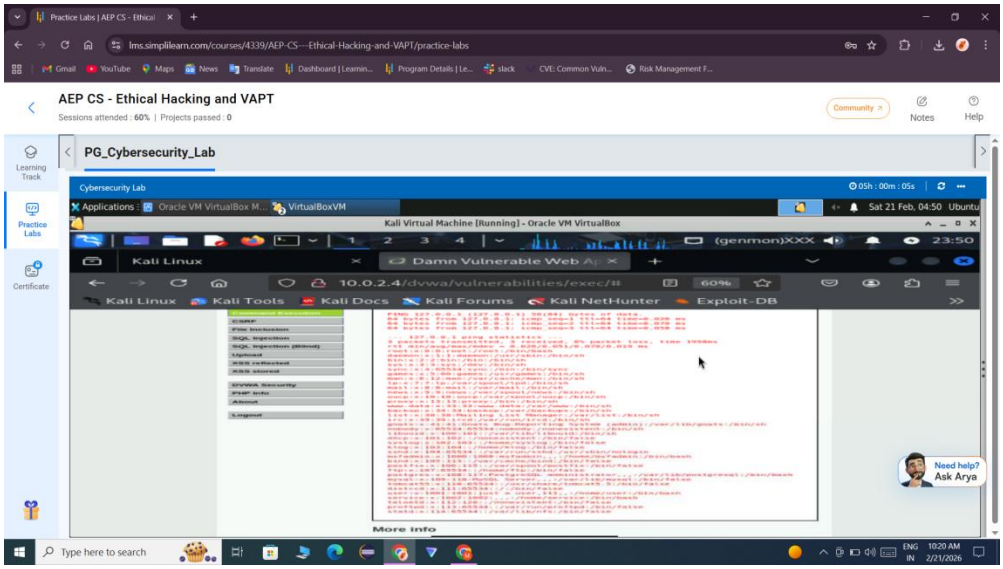
Phase 1: Baseline Testing

- **Description:** Verified the normal operation of the "Ping for FREE" tool by entering a standard loopback IP.
- **Payload:** `127.0.0.1`
- **Observation:** The application returned standard ICMP ping results.
- 

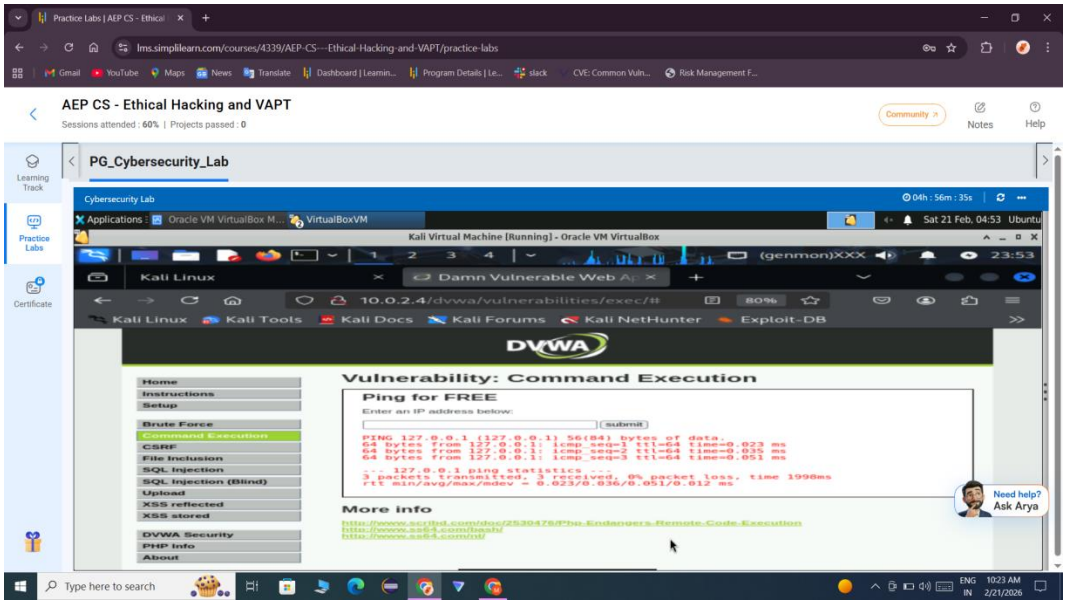
Phase 2: Direct Command Injection

- **Description:** Injected the `whoami` command using a semicolon (`;`) separator to determine the user account running the web service.
- **Payload:** `127.0.0.1 ; whoami`
- **Observation:** The server executed the command and returned `www-data`, confirming the vulnerability.
- 

Phase 3: Sensitive Data Exfiltration (High Impact)

- **Description:** Attempted to read the system's user account configuration file to demonstrate the severity of the flaw.
- **Payload:** `127.0.0.1 ; cat /etc/passwd`
- **Observation:** Successfully retrieved a full list of system users, representing a critical data breach.
- 

Phase 4: Blind Command Injection

- **Description:** Demonstrated a timing-based attack to prove execution capability even when text output is suppressed.
- **Payload:** `127.0.0.1 ; sleep 10`
- **Observation:** The application delayed its response by exactly 10 seconds, confirming blind execution.
- 

---

4. Mitigation & Secure Coding Practices

To secure the logistics application, the following measures are recommended:

1. **Input Validation:** Implement a strict allowlist that only permits valid IP address formats (numbers and dots).
2. **Avoid Shell Execution:** Replace system-level calls with secure, built-in programming language functions.
3. **Sanitization:** If shell commands are necessary, use "escaping" functions to neutralize meta-characters like `;`, `&`, and `|`.

---

5. Conclusion

Based on the penetration testing conducted, the logistics web application was found to have a **Critical** vulnerability in the form of OS Command Injection. The ability to execute system-level commands and exfiltrate sensitive data like `/etc/passwd` poses a severe risk to the organization's data integrity and server availability.